

EyouCMS ≤1.8.2 会员投稿+前台下载链路未授权 SSRF（响应回读）

一、漏洞概述

项目	内容
漏洞名称	EyouCMS <code>remote_file_to_local()</code> 缺失 SSRF 校验导致前台 SSRF（可回读响应）
影响产品	EyouCMS（易优CMS），实测 v1.8.2；≤1.8.2 所有含该函数的版本
漏洞类型	SSRF（服务器端请求伪造），CNVD 分类：通用型漏洞-服务器端请求伪造
危害等级	高（可探测并读取内网/本机任意 HTTP 服务响应体，含云元数据 169.254.169.254）
触发前提	会员可注册（默认开启）+ 会员投稿开启（ <code>users_open_release=1</code> 默认值）+ 下载模型可投稿（ <code>is_release=1</code> 默认值）——均为出厂默认配置

二、漏洞成因（白盒源码分析）

漏洞由四道"各自看起来合理"的防线串联失效构成。先看链路鸟瞰，再逐环引用源码讲解：

```
1  攻击者注册会员
2  | ① 投稿 POST article_add  remote_file[]=http://内网地址/poc.txt
3  ▼
4  入库：URL 零校验，uhash=md5(url)                ← 注入点（2.1）
5  | ② 游客 GET downfile?id=&uhash=
6  ▼
7  downfile：不查稿件状态、外链视为存在            ← 触发点（2.2）
8  | ③ 扩展名是 .txt → 走"本地化"分支
9  ▼
10 remote_file_to_local()：全站唯一没调
11 validateRemoteUrl() 的远程抓取函数                ← sink（2.4）
12 | get_headers → readfile → 落盘 uploads/soft/
13 ▼ ④ 302 → download_file
14 回读：把存下来的"内网响应"原样给游客            ← 危害兑现（2.5）
```

2.1 注入点：会员投稿 remote_file[] 零校验入库

`application/user/model/DownloadFile.php:105-125`（会员投稿保存下载附件的实际代码）：

```

1  if (!empty($post['remote_file'])) {
2      foreach($post['remote_file'] as $kkk => $vvv)
3      {
4          $vvv = trim($vvv); // ← 对 URL 唯一的"处理"
5          if($vvv == null || empty($vvv)) continue;
6          ...
7          'file_url' => $vvv, // ← 直接入库 ey_download_file
8          'uhash' => md5($vvv), // ← "防伪哈希" = md5(URL 本身)
9          'is_remote' => 1,

```

对 URL 的全部"校验"只有 `trim()`：没有协议白名单、没有域名限制、没有内网地址检查。`uhash=md5($vvv)` 本意是让下载链接不可伪造，但 URL 是攻击者自己填写的，md5 可自行计算——该防线对攻击者无效。

2.2 触发点：游客可达的 `downfile()`

application/home/controller/view.php:363-406:

```

1  $map = array('a.file_id' => $file_id, 'a.uhash' => $uhash);
2  $result = Db::name('download_file')
3      ->join('__ARCHIVES__ b', 'a.aid = b.aid', 'LEFT')
4      ->where($map)->find();
5  ...
6  if (empty($result) || (!is_http_url($result['file_url']) && !file_exists(...))) {
7      $this->error('下载文件不存在!');

```

三处"放行"：

- JOIN 了 `ey_archives` 却不按 `arcrank/is_del` 过滤——待审核、已删除稿件照样可触发（前台正常访问同稿返回 404，预期访问控制存在，此处遗漏）；
- `!is_http_url(...) && !file_exists(...)`：URL 为 http 开头即短路 `file_exists`，外链直接视为"文件存在"；
- 会员等级/付费闸门仅在 `is_download_pay` 插件开启或 `arc_level_id>0` 时生效，默认下载栏目两者均关/为 0，游客畅通。

2.3 分支决策：扩展名白名单

application/home/controller/view.php:509-512:

```

1  $url_arr = explode('.', $result['file_url']);
2  $ext = $url_arr[count($url_arr)-1];
3  $image_ext_arr = array_merge($image_ext_arr, ['txt']);
4  if (in_array($ext, $image_ext_arr)){
5      $result['file_url'] = remote_file_to_local($result['file_url']); // ← sink

```

设计意图良性（站长贴的外链图片/txt 本地化缓存，避免外站资源失效），但"是否抓取"的决定被交给**扩展名字符串**：`.txt` 只是一个后缀，`http://127.0.0.1:8877/poc.txt` 与真实图床在服务端看来没有任何区别。**扩展名不是安全边界，URL 的目标才是——而目标从未被检查。**

2.4 Sink: remote_file_to_local() 全站唯一未校验的远程抓取函数

EyouCMS 为修复历史 SSRF（CVE-2025-15373 一类）在所有远程抓取函数中加入了统一校验函数

`validateRemoteUrl()`：

1	<code>application/function.php:1654</code>	<code>saveRemote()</code>	→ <code>validateRemoteUrl(\$imgUrl)</code>	✓ 已校验
2	<code>application/function.php:1997</code>	<code>saveRemoteVideo()</code>	→ <code>validateRemoteUrl(\$videoUrl)</code>	✓ 已校验
3	<code>application/function.php:2262</code>	<code>saveRemoteFile()</code>	→ <code>validateRemoteUrl(\$fileUrl)</code>	✓ 已校验
4	<code>application/function.php:4070</code>	(Ueditor/远程图片)	→ <code>validateRemoteUrl(\$imgUrl)</code>	✓ 已 校验
5	<code>application/function.php:3825</code>	<code>remote_file_to_local()</code>	→ 【无任何校验】	X 遗 漏

`remote_file_to_local()` (`application/function.php:3825`) 是唯一没有调用 `validateRemoteUrl()` 的远程抓取函数，对传入 URL 仅做：

- `application/function.php:3875` 本站/第三方存储域名的正则跳过（内部 IP 不匹配，直接放行）；
- `application/function.php:3880` `^http(s?)://` 格式检查——只查"长得像 URL"；
- `application/function.php:3883` `get_headers()` 死链检查——只看 `heads[0]` 是否含 "200"，回答的是"链接活着吗"而非"目标合法吗"（`get_headers($url)` 这一发请求本身即是服务器代发的 SSRF）；
- `application/function.php:3903` `readfile($imgUrl, false, $context)` 完整抓取响应体；
- `application/function.php:3921` `file_put_contents()` 将响应体保存到 `uploads/soft/日期/` 下并返回本地 URL——内网内容被搬到公网可直接下载的目录。

2.5 回读: download_file 会话校验只防第三者

`application/home/controller/view.php:586-589`：

```
1 $value = cookie($file_id.$uhash_mch); // 读名为 "{file_id}{加密uhash}" 的专用 Cookie
2 if (empty($value)) {
3     $this->error('下载地址已失效，请在下载详情页进行下载！', $arcurl);
4 }
```

`downfile` 的 302 响应会 `Set-Cookie` 该专用 Cookie，`download_file` 校验其存在——属于防第三方直跳的防盗链设计，不防攻击者本人：其自己发起 `downfile`、自带 Cookie 回读，内网响应体原样到手。

2.6 现有防线逐条失效对照

防线	看似作用	为何失效
<code>uhash=md5(url)</code>	防伪造链接	URL 是攻击者填的，md5 自己可算
外链"文件存在"检查	防无效下载	<code>is_http_url</code> 直接短路
付费/等级闸门	限制下载权限	默认关闭

防线	看似作用	为何失效
扩展名白名单	限制本地化范围	<code>.txt</code> 后缀可指向任意内网地址
<code>get_headers</code> 返回 200	防死链	内网服务本来返回 200
<code>download_file</code> Cookie 绑定	防盗链	不防攻击者本人
稿件审核状态	——	<code>downfile()</code> 不查 <code>arcrank/is_del</code>

2.7 根因小结

后台专用"远程外链"能力（原设计输入者为可信站长）被会员投稿路径复用，输入者变为任意注册用户，但 URL 校验、稿件可见性、目标合法性三层信任假设均未随之迁移；叠加 CVE-2025-15373 修复时 `remote_file_to_local()` 被遗漏，最终形成匿名可回读 SSRF。

2.8 完整触发链路（会员最低权限触发、游客可回读）

```
1 ① 匿名注册会员（注册默认开启，注册/登录验证码默认关闭 users_login/users_reg is_on=0）
2 ② POST /index.php?m=user&c=UsersRelease&a=article_add
3   └ application/user/controller/UsersRelease.php:201 article_add()
4   └ application/user/model/UsersRelease.php:41-73 afterSave()
5   └ application/user/model/DownloadFile.php:64-129 savefile()
6       → $post['remote_file'][] 的 URL 原样入库 ey_download_file (file_url /
    uhash=md5(url))，无任何 URL 校验
7 ③ 会员中心"稿件编辑"页回显自身稿件的 file_id 与 uhash（无门槛，攻击者自查）
8 ④ 游客（无需登录）GET /index.php?m=home&c=View&a=downfile&id=<file_id>&uhash=md5(file_url)
9   └ application/home/controller/View.php:363 downfile()
10     - 仅校验 file_id + uhash 匹配，不校验稿件审核状态（arcrank=-1 待审核亦可触发）
11     - view.php:505-515 外链扩展名为图片或 txt 时 → remote_file_to_local($url)
12     - 抓取"内网 URL"的响应体 → 保存为 uploads/soft/.../*.txt → 302 跳转 download_file
13     - 游客随后收到该文件（application/octet-stream），即内网服务响应体原文
```

即：低权限会员将任意外链注入下载模型，任意游客点击下载即可让服务器抓取该 URL 并把响应体原样回读——构成可回读的完整 SSRF，可访问本机/内网仅对内开放的 HTTP 服务（如 127.0.0.1 上的管理面板、169.254.169.254 云元数据、内网 API 等）。

三、影响版本

- 实测：EyouCMS v1.8.2（官方最新，gh.ddlc.top/weng-xianhu/eyoucms master 源码）
- 推断：≤1.8.2 所有引入 `remote_file_to_local()` 且未在其中调用 `validateRemoteUrl()` 的版本
- 影响面（FOFA 实测 2026-09-19）：`app="EyouCMS"` 共 **42,516** 个资产；`body="ey_global.js?v=v1.8.2"`（v1.8.2 精确指纹）**2,087** 个；`body="ey_global.js" && body="a=downfile"`（下载模型在用、链路入口收录可达）**90** 个页面，样本记录见同目录 `fofa_assets_sample.md`

四、修复建议

在 `remote_file_to_local()`（application/function.php:3825）入口处对每个候选 URL 调用与其他抓取函数一致的 `validateRemoteUrl($imgUrl)`，校验不通过直接 `continue`；同时建议：

1. 校验通过后用解析出的 IP 建立连接（防止 DNS rebinding 绕过 `validateRemoteUrl` 本身）；
2. `get_headers` 与实际抓取复用同一 IP；
3. 下载模型 `savefile()` 侧对 `remote_file[]` 做同样的 URL 白名单校验（纵深防御，注入时拦截优于触发时拦截）；
4. `view::downfile()` (View.php:363) 查询条件补充 `arcrank >= 0 AND is_del = 0`，与前台可见性对齐，消除"待审核/已删除稿件可触发"；
5. 注意扩展名白名单不能作为安全边界：是否允许抓取的判定必须基于 URL 目标（解析后的 IP），而非文件后缀字符串。